

Penetration Testing

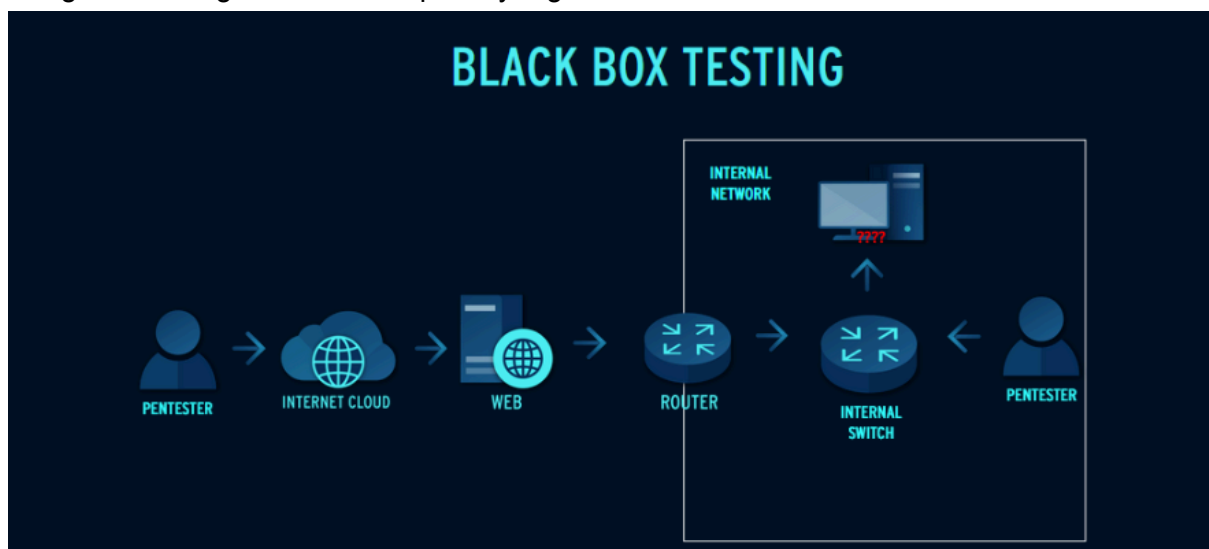
Penetration test is an **authorised audit** of a computer system's security and defences as agreed by the owners of the systems. The legality of penetration is pretty clear-cut in this sense; anything that falls outside of this agreement is deemed unauthorised.

We must first define hacking in the context of cybersecurity before we understand penetration testing. Hacking is the practice of taking advantage of flaws in a network, application, or system to obtain unauthorized access or carry out unexpected tasks. This could entail getting around security measures, changing how software behaves, or gaining unauthorized access to data.

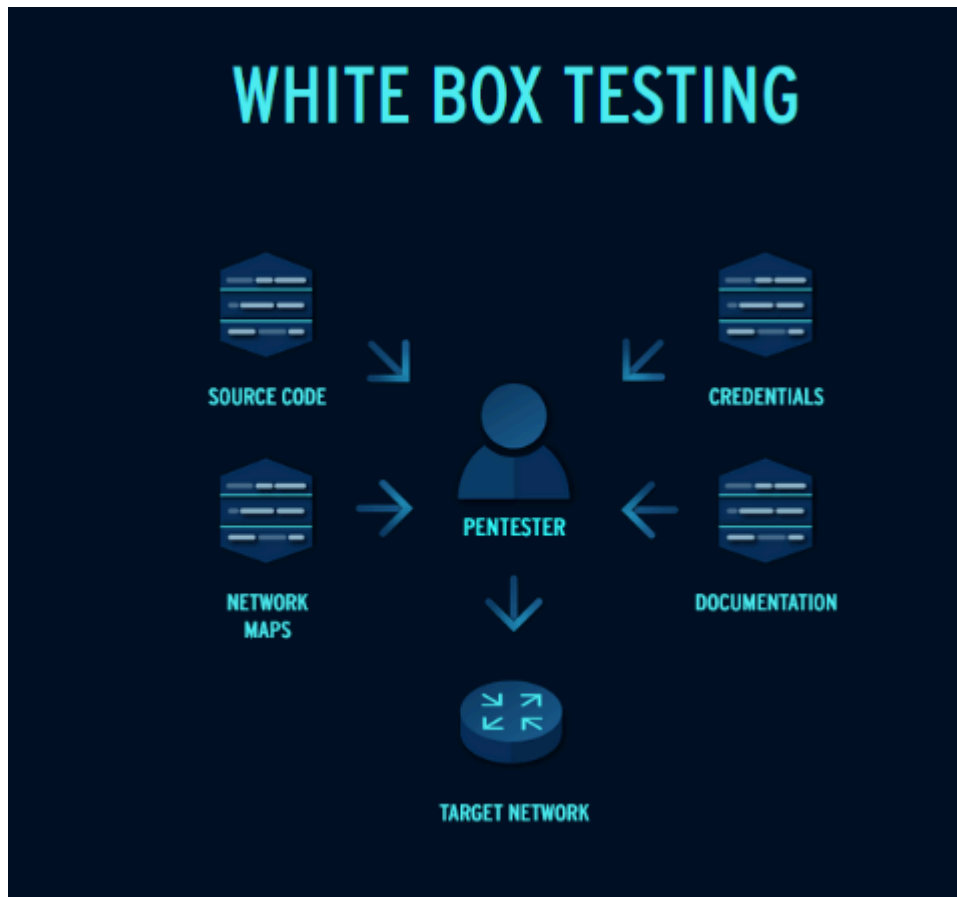
The word "hacking" is frequently used negatively, usually in reference to malicious cybercriminals breaking into systems. But hacking isn't always a bad thing. It actually comes in a variety of shapes and purposes, some of which are morally and legally righteous. For instance, ethical hacking, sometimes referred to as white-hat hacking, is the practice of applying hacking expertise to assist organizations in locating and addressing security flaws before malicious actors have the opportunity to take advantage of them.

Organizations can use penetration testing, also known as a pentest, to identify vulnerabilities in a system, network, or application by simulating a real cyberattack. It is performed by cybersecurity experts referred to as **ethical hackers** or **white-hat hackers**, whose role is to act and think like attackers with authorization. Finding and safely taking advantage of vulnerabilities before malevolent hackers do is the aim.

The scope is a crucial component of any pentest. This guarantees that the entire procedure remains lawful and under control by outlining what can and cannot be tested. This is agreed upon up front by the testing team and the organization, helping to safeguard sensitive data and guaranteeing adherence to privacy regulations.



Black-box penetration testing is a type of security assessment where the tester has no **prior knowledge** of the target environment—similar to how a real-world attacker would operate. The purpose of this method is to simulate an external threat and identify vulnerabilities from an outsider’s perspective. Testers are not provided with internal documentation, credentials, or architecture details



White-box penetration testing is a highly detailed assessment where the tester is given **full access** to the target environment. This may include source code, configuration files, credentials, network maps, and architectural documentation. Because the tester has complete visibility, white-box testing allows for a deep and efficient evaluation of the system, including logic flaws, insecure coding practices, and misconfigurations

Aspect	Black-Box	Grey-Box	White-Box
Tester Knowledge	No knowledge of the target	Partial knowledge	Full knowledge
Access Level	No credentials or documentation	Limited credentials or system insight	Full access to code, configs, credentials
Testing Focus	Real-world attack scenarios	Mixed attack paths (internal + external)	Thorough code/system-level analysis
Time & Depth	Slower, less depth	Moderate depth and speed	Fast and deep testing
Common Use Case	External threat simulation	Balanced risk assessment	Development & code auditing

Grey-box testing is a practical middle ground that offers the best of both worlds, it combines the realism of black-box testing with the efficiency of white-box testing.

External Penetration Testing

External penetration tests simulate attacks originating **outside the organization's network perimeter**. These tests focus on **internet-facing assets**, which are often the first point of contact for real-world attackers.

Common Targets Include:

- Web applications and web servers
- APIs and external services
- Perimeter firewalls and gateways
- VPN portals and remote access systems

Purpose:

- Evaluate the organization's exposure to external threats
- Identify vulnerabilities accessible over the public internet
- Assess the effectiveness of perimeter defenses and patch management
- Test authentication, session management, and input validation on public interfaces

This type of testing is crucial for organizations with a significant digital footprint or customer-facing services.

Internal Penetration Testing

Internal penetration tests simulate threats **originating within the organization's trusted network**. This reflects scenarios such as a **malicious insider**, a **compromised employee account**, or an **attacker who has already bypassed external defenses** (e.g., via a phishing campaign or VPN compromise).

Scenarios May Include:

- Black-box testing with limited internal knowledge (e.g., a rogue device or stolen credentials)
- Credentialed testing from a standard user perspective
- Evaluating domain privilege escalation paths
- Testing lateral movement and segmentation controls

Scope Type	Focus Areas	Common Goals
Web Application	• Input validation (e.g., XSS, SQLi) • Auth/session flaws • Logic issues	Identify flaws in user input handling, access control, and business logic
Infrastructure	• Network services • OS vulnerabilities • Misconfigurations • Patch management	Test internal/external networks and foundational systems for weaknesses
API	• Broken authentication • Input validation • Rate limiting • Data exposure	Ensure secure handling of API requests and enforce proper access control
Cloud Environment	• Misconfigured services • IAM roles • Public-facing assets • Privilege escalation	Assess security posture of cloud-hosted resources and configurations
Mobile Application	• Insecure local storage • Weak TLS • API usage • Reverse engineering risks	Detect data exposure and code weaknesses in iOS/Android mobile apps

Aspect	Vulnerability Scanning	Penetration Testing
Approach	Automated	Manual (with some automation)
Depth	Surface-level analysis	In-depth exploitation
Objective	Identify known vulnerabilities	Assess real-world risk
Frequency	Regular (e.g., weekly/monthly)	Periodic or Ad-Hoc
Confirmation of Risk	No	Yes

Penetration Testing vs Vulnerability Scanning

PT vs VS

Explained

Penetration Testing vs Vulnerability Scanning

While both penetration testing and vulnerability scanning are important components of a strong cybersecurity program, they serve different purposes.

Vulnerability scanning is an automated process that identifies known security weaknesses in systems, networks, or applications. These scans generate reports listing potential vulnerabilities based on signatures and configurations, but they do not confirm whether those flaws can actually be exploited.

Common vulnerability scanners include:

- **Nessus** – widely used for network and host vulnerability scanning
- **OpenVAS** – an open-source alternative for vulnerability assessment
- **Qualys** – a cloud-based scanner popular in enterprise environments
- **Nexpose (by Rapid7)** – integrates well with threat intelligence and remediation workflows

Penetration testing, on the other hand, is a manual and more in-depth assessment conducted by ethical hackers. It goes beyond identifying vulnerabilities—it involves actively attempting to exploit them to determine how far an attacker could get, what data they could access, and how systems could be manipulated in a real-world scenario.

Penetration testers often use **automated vulnerability scanners as part of their process**, especially to catch “low-hanging fruit” such as missing patches, outdated software, or misconfigurations. However, the real value of a penetration test lies in the human-driven analysis, creative thinking, and exploitation that go beyond what automated tools can detect.